

风险与合规摘要

高 沙箱 · 数据 中 成本波动 · 合规

风险与合规摘要

Executive Summary (EN): Top risks—sandbox isolation cost and compute price volatility. Mitigate via pass-through pricing and private deploy. Domestic compliance requires ICP and content policies.

风险矩阵

风险	等级	影响	缓解措施
安全沙箱	高	Agent 执行代码/命令 → 串租户或主机沦陷	容器隔离、gVisor/Firecracker/E2B; 限常驻
Token/媒体成本波动	中	毛利被挤压	积分转嫁 + 智能路由宣传 + 限价策略
大厂通用 Agent	中	价格战、功能重叠	垂直营销飞轮 + 模板深度
数据泄露	高	品牌与法律责任	租户隔离、JWT、路径校验、审计
内容合规	中	国内上线审核	生成内容策略、敏感词、人工复核流程(待建)
备案与隐私	中	公网 SaaS 无法运营	ICP、隐私政策、用户协议

安全沙箱（技术向摘要）

- Agent 可调用：bash、浏览器、文件读写、MCP
- SaaS 必须：**每租户 / 每任务** 可隔离执行环境
- Always-On 常驻：**高成本**，需配额与空闲回收
- 用户叙事：见 [安全白皮书](#)

成本失控防护

机制

说明

路由	降低单次任务 token
并发限制	免费版无常驻
监控告警	异常用量租户

合规清单（公网 SaaS 前）

- ☐ 用户协议与隐私政策
- ☐ ICP 备案（中国大陆）
- ☐ 注册验证码与反刷（已：Redis 图形验证码）
- ☐ 默认管理员改密（已提示：admin/admin123 公网前必改）
- ☐ 遥测默认关闭策略（见 brand-security-audit）
- ☐ 内容安全策略（待建）

对外怎么说风险

对投资/法务：全文透明，本文件为准。

对销售客户：强调已落地的隔离、JWT、云端枢纽、用量审计；沙箱与合规按部署形态说明，不过度承诺未上线认证（如 ISO27001 待补充）。

相关文档

- `docs/saas-feasibility-report.md` §四
- `docs/brand-security-audit.md`
- [安全与信任白皮书](#)